



The TripWire Bible

The control plane for AI agent actions

Product, market, business model, and three-year plan. One document for investors, judges, and the founding team.

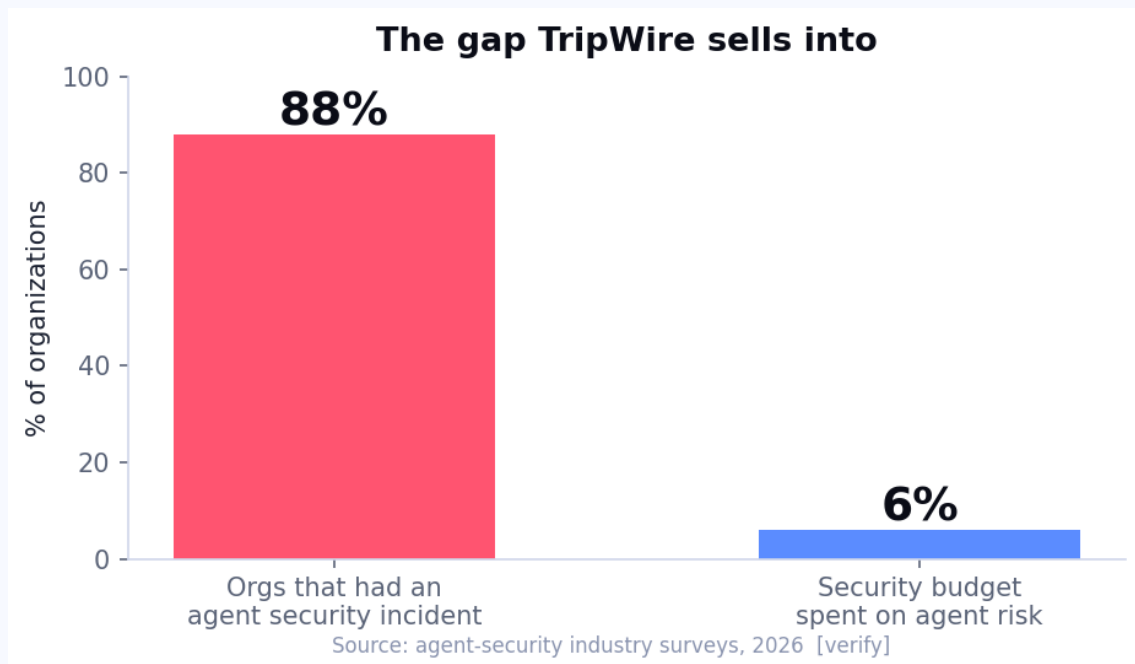
Microsoft Build AI 2026 - Security in the Agentic Future

Kundan Khatri - github.com/KundanKhatri/Tripwire

Figures marked [verify] are directional; confirm before external/financial use.

Make it safe to give an AI agent power

Enterprises are handing AI agents real authority - to read data, call tools, spend money, and act on their own. The security model has not caught up. 88% of organizations have already had an agent security incident, yet only ~6% of security budget covers agent risk. TripWire closes that gap.



LLM firewalls inspect the text going in. TripWire governs what the agent is allowed to do - across the three boundaries every agent exposes (prompt, tools/MCP, memory) - and proves nothing harmful leaves, with a full audit trail. It is the action-layer control plane incumbents under-serve.

The one-line

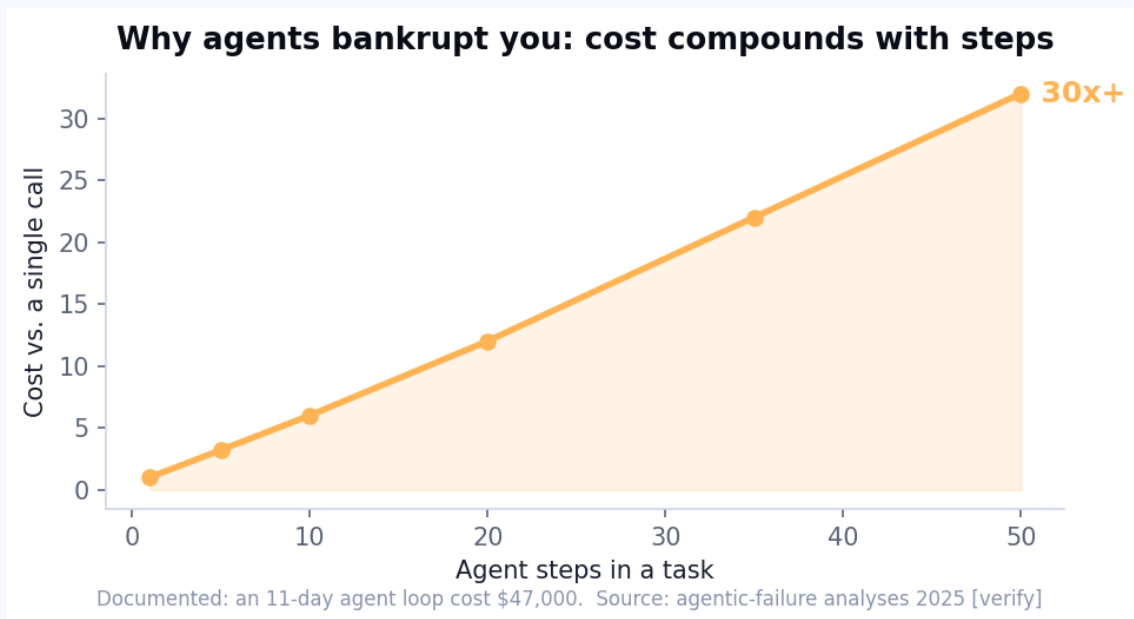
TripWire is the runtime security, identity, and governance layer enterprises install before they let agents touch production systems. Open-core, provider-agnostic, built on Azure.

THE PROBLEM

Agents are powerful - and unguarded

The same autonomy that makes agents useful makes them dangerous when fooled. The damage is documented and concrete:

- **Indirect prompt injection** Hidden instructions in a document/email/web page the agent reads - the #1 OWASP agent risk.
- **Tool poisoning via MCP** Malicious instructions in tool metadata; first malicious MCP package hit registries Sep 2025.
- **Memory poisoning** False facts implanted into long-term memory persist across sessions.
- **Runaway cost loops** A documented agent loop ran 11 days = \$47,000; cost compounds 30x+ at 50 steps.
- **No audit trail** EU AI Act penalties begin Aug 2026; few teams can show what their agents did.



One control plane, three boundaries

TripWire runs inline as a 5-layer pipeline built on three reusable primitives - provenance, taint/canary, and inline policy - applied to the prompt, tool/MCP, and memory boundaries.

L1

Semantic Firewall

Patterns + Azure Prompt Shields + embedding similarity to a known-attack corpus.

L2

Capability Provenance

Tool calls need a signed token scoped to the real user request. Injected calls have no authority - denied.

L3

Canary Tripwires

Decoy secrets; if one ever leaves, it is proof of exfiltration. Zero false positives.

L4

Behavioral Anomaly

Scores when the agent's actions diverge from the user's goal.

L5

Learning Classifier

Curated, human-in-the-loop model that improves from real attacks.

The standout

L2 + L3 stop attacks an LLM firewall can't - like indirect injection, where the user request is benign and the attack hides in tool output. We don't recognize every attack; we deny it authority (L2) and catch the theft (L3).

It works - watch an attack get blocked

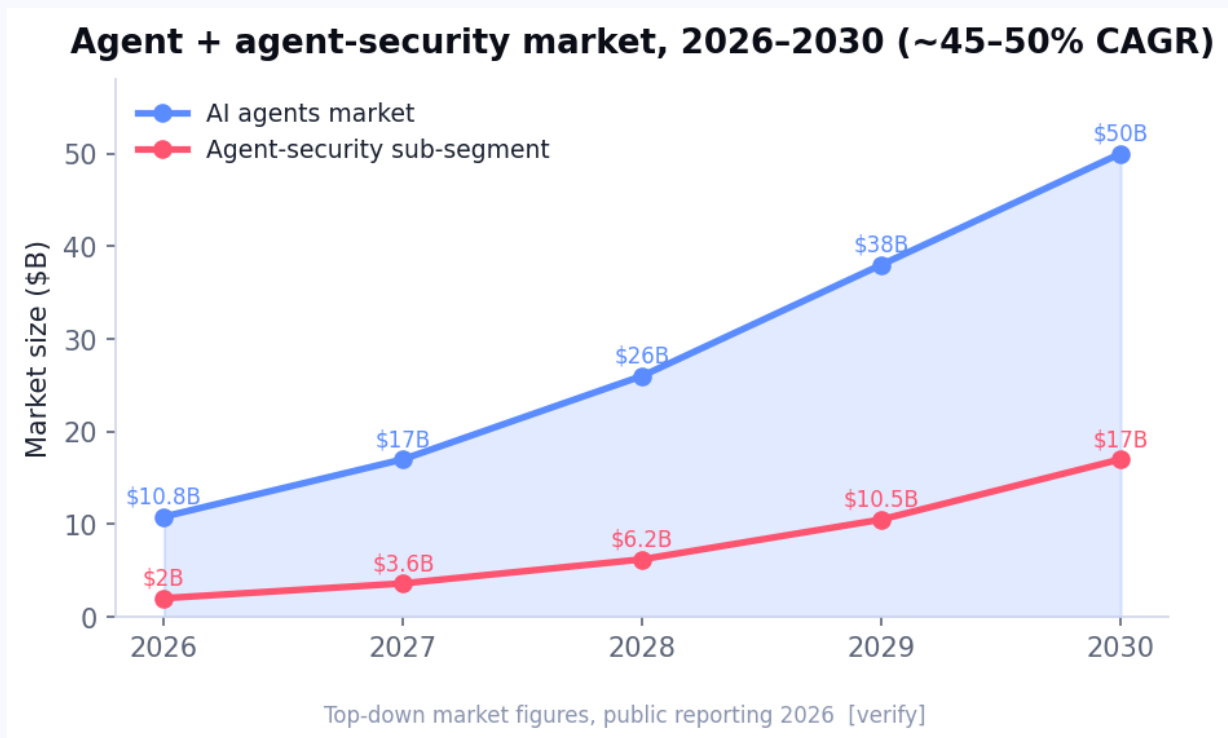
A victim agent is asked only to summarize a document. The document is poisoned with a hidden instruction to read a secret file and email it to an attacker. The user authorized only 'read_document', so every malicious tool call is denied for lack of provenance:

```
[plan]    User asked to summarize a document.  
[tool]    Agent reads the document (authorized).  
[blocked] Injection -> read_file.  L2: not in granted scope [read_document]  
[blocked] Injection -> send_email. L2: not in granted scope [read_document]  
[final]   Attack neutralized. Nothing sensitive left the boundary.
```

Verified, not claimed

13 automated tests green. Live Azure verified (embeddings + Prompt Shields).
Benchmarks report block rate WITH false-positive rate; provenance + canary layers are zero-FP by construction. Try it: kundankhatri.github.io/Tripwire

Big, new, and growing fast

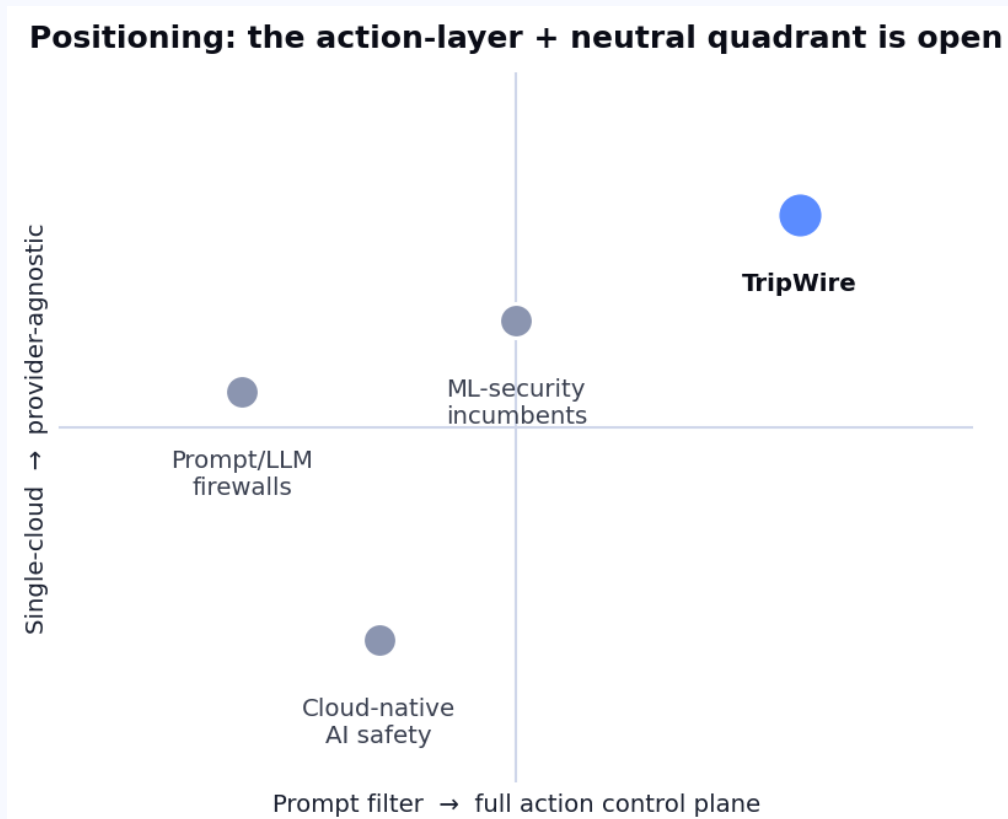


Enterprise spend on agentic AI is projected near \$200B for 2026. The agent-security sub-segment is the fastest-growing slice - ~\$392M was funded around RSAC 2026 alone (Noma \$100M, HiddenLayer \$50M). The attack surface (MCP, agent memory, agent identity) is brand new, and regulation (EU AI Act) forces spend on a deadline.

Why now

Agents crossed from pilots to production in 2025-26; the boundaries we secure didn't exist two years ago; and security budget is shifting to agent risk from a near-zero base.

The open quadrant



Incumbents (Lakera, HiddenLayer, Noma, Prompt Security, Protect AI, Robust Intelligence) are mostly prompt/LLM-firewall first and often single-cloud. TripWire's wedge is agent ACTION security - the control plane over tools, identity, and memory - and it is provider-agnostic.

Moat, most durable first:

- Data - telemetry across millions of actions -> detection + an agent risk score.
- Identity system-of-record - once we issue agent identities, switching is costly.
- Audit/compliance lock-in - we hold the legal record of agent behavior.
- Provider-agnostic - defensible against any single platform absorbing us.

From defense pipeline to platform

F1

Agent Identity Ledger

Cryptographic identity + lifecycle + kill-switch for every agent (NHI).

F2

MCP Tool Firewall

Scan + hash-pin + sandbox tools; defeat poisoning & rug-pulls.

F3

Cost & Loop Governor

Detect loops, enforce budgets, circuit-break before the \$47K bill.

F4

Memory-Poisoning Shield

Provenance + taint for long-term agent memory.

F5

Compliance Audit Ledger

Signed, replayable action trail; EU AI Act / SOC2-ready.

V1

Agent Trust Fabric

Cross-org agent-to-agent trust: PKI + reputation for non-human identities.

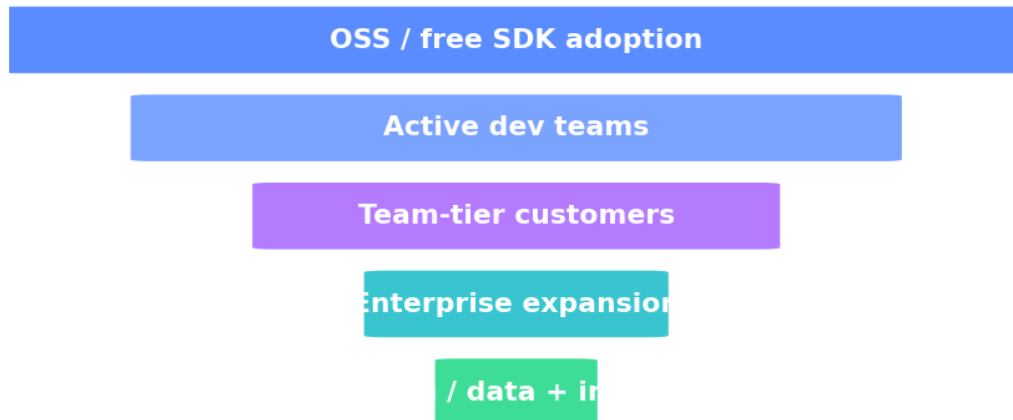
V2

Agent Risk Score + Insurance

Telemetry becomes an actuarial dataset; underwrite agent-loss cover.

Land with developers, expand to enterprise

Bottom-up GTM: land with developers, expand to enterprise



- 1 Adopt** OSS SDK + L1 free. Win the dev wiring up an agent who just read an MCP-poisoning headline.
- 2 Land** One agent team buys Team tier for a single production agent.
- 3 Expand** Org-wide policy, identity ledger, audit module -> Enterprise.
- 4 Pull** EU AI Act deadline is the urgency lever into regulated buyers.

Buyer & champion

Champion = platform/AI-eng lead feeling the pain. Buyer = Director of AppSec / CISO holding the budget and the EU AI Act risk. Pricing is per protected agent - aligned with what's exploding (agent count) and the value (each agent is a risk retired).

Open-core, four revenue streams

OSS / Free
\$0

SDK, L1 firewall, single-agent provenance. The adoption funnel.

Team
~\$2-5K/mo

Full 5-layer pipeline, MCP firewall, cost governor, dashboard, SSO.

Enterprise
~\$60-250K/yr

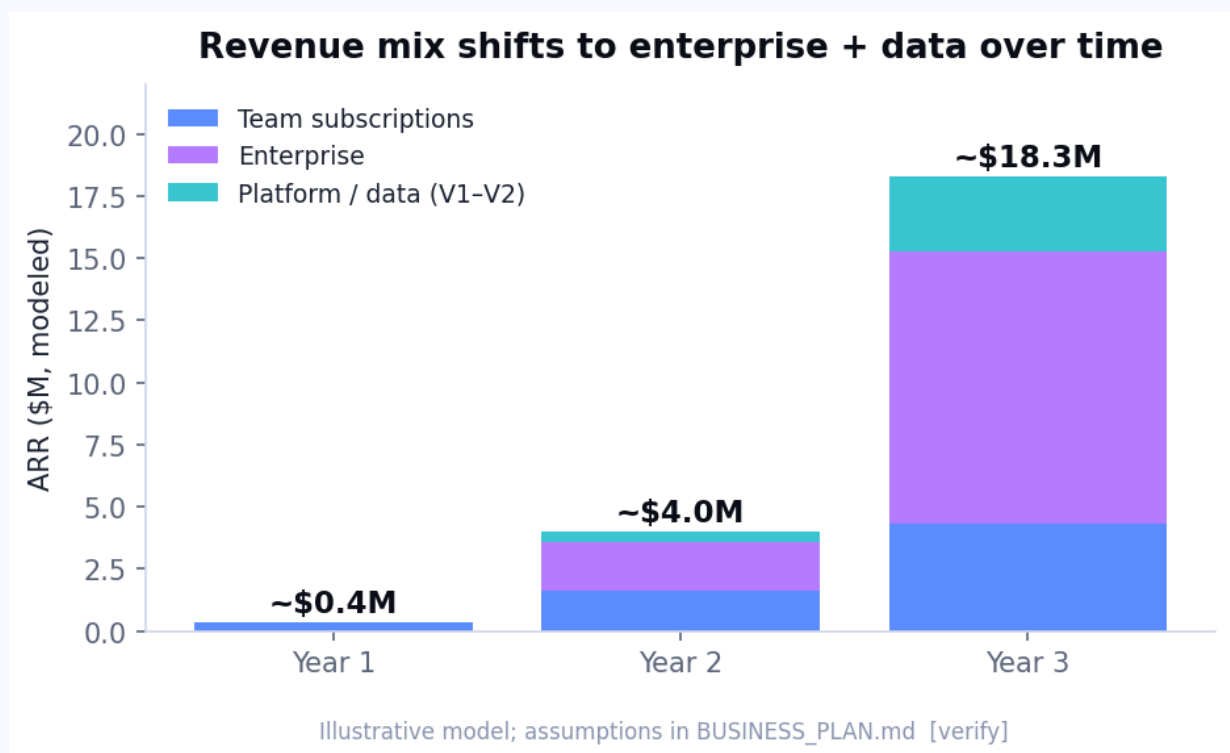
Identity ledger, memory shield, compliance audit, policy, SLA, VPC.

Platform / data
usage + %

Trust fabric + risk score + insurance (the data moat).

Revenue streams:

(1) seat/agent subscriptions (2) usage (actions inspected) (3) compliance/audit module (4) risk-score API + insurance share (later).



Roadmap and modeled ARR

Year 1 - Wedge

~\$0.4M ARR

5-layer pipeline + MCP firewall (F2) + cost governor (F3). OSS launch, 3-5 design partners, first 10 Team customers.

Year 2 - Platform

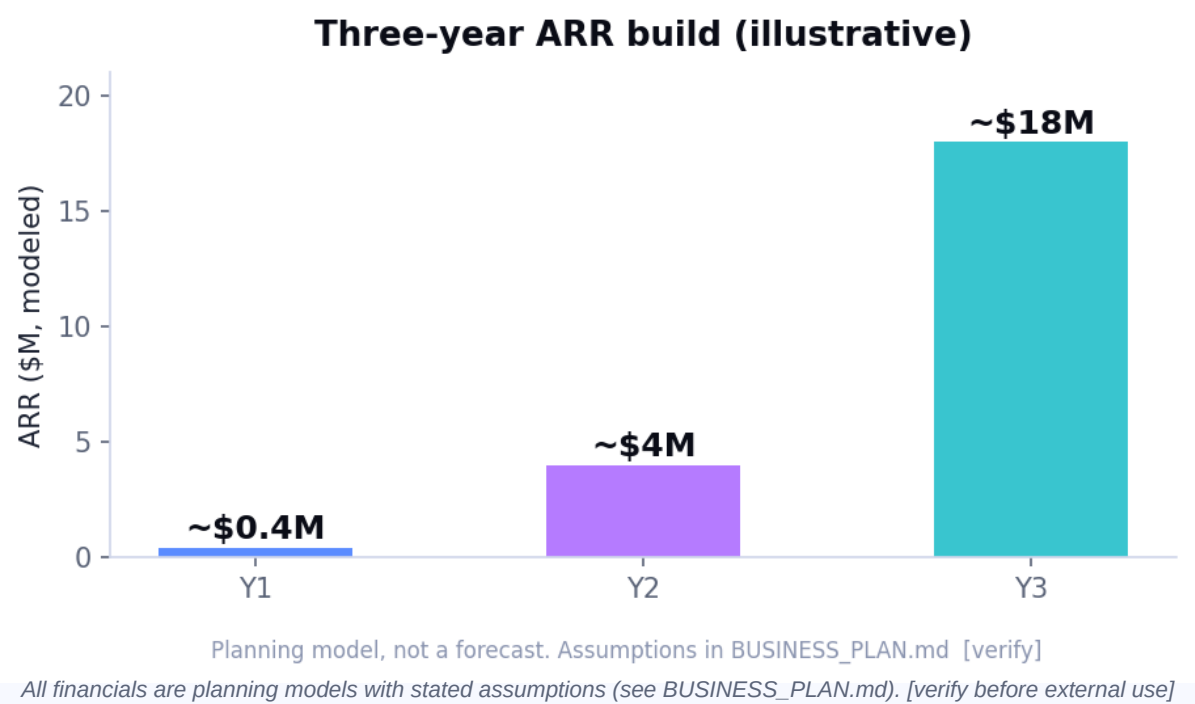
~\$4M ARR

Identity ledger (F1) + compliance audit (F5) + memory shield (F4). First enterprise contracts, SOC2, marketplace.

Year 3 - Data moat

~\$18M ARR

Risk score (V2 alpha) + trust fabric (V1 pilot). Land-and-expand + partner channel.



Risks, mitigations & the ask

Platform absorption (Azure/OpenAI ship native)

-> Provider-agnostic; own identity + audit + cross-vendor data.

Crowded market

-> Wedge on action/tool/memory boundary, not prompt firewall.

Long enterprise sales cycles

-> OSS bottom-up first; compliance deadline as urgency.

False positives erode trust

-> Lead with zero-FP primitives; ranges, not hero numbers.

Learning-loop data poisoning

-> Human-in-loop labeling; never auto-train on attacker data.

The ask

Raise a pre-seed/seed to fund the Year-1 wedge: ship F2+F3, land design partners, prove the open-core funnel converts. Use of funds ~70% engineering, ~20% GTM/dev-rel, ~10% compliance/SOC2. (Fill amount + terms before use.)



Make it safe to give an agent power.

TripWire - the control plane for AI agent actions.

kundankhatri.github.io/Tripwire - github.com/KundanKhatri/Tripwire